



Procaín Consulting & Services Pvt. Ltd

1st Floor, Earthen Phoenix,
No. 12, Sanjeevappa Layout,
10th E cross Nagvarapalya,
C.V.Raman Nagar, Bangalore – 56 00 93
E: info@procaínconsulting.com
T: +91 80 41624400

Web Application Penetration Test Report

Date: March 02, 2026

Confidential Document: Not to be circulated or reproduced without appropriate Authorization.

DOCUMENT DISTRIBUTION

Report Prepared By	Earnest Wesley
Report Reviewed By	Abhijeet Shikhare

Customer Name	Accionlabs
Audit Type	Web Application Penetration Testing Security Assessment
Audit Duration	02 nd March 2026

DISCLAIMER

This document is strictly confidential and is intended only for the use of our client.

Nothing contained in this document shall be construed as conferring by implication, estoppels, or otherwise, any license or right to any copyright, patent, trademark or other proprietary interest of Infra Penetration Testing security assessment team.

The findings in this report reflect the conditions found during the assessment period (Vulnerability / exploit reported to the date of the report and also current release / version of application) and do not necessarily reflect conditions post assessment.

Contents

1. Background	4
a. Introduction	4
b. Objective	4
c. Scope.....	4
d. Out of Scope.....	5
2. Summary of Findings.....	6
3. Web Application Vulnerability Distribution by Severity	7
4. Vulnerability Details	8
4.1 Subdomain Takeover via Dangling DNS	8
5.VAPT Methodology	14
5.1 Vulnerability Risk Classification	15
5.2 Threat Severity Risk Matrix	16

1. Background

a. Introduction

The objective of this exercise was to perform vulnerability assessment of the applications in scope to determine if they were vulnerable to attacks and exploitation. The test consisted of automated security vulnerability scanning, supported by manual testing to detect and exploit vulnerabilities.

The assessment was conducted with an aim to identify the security vulnerabilities in the Applications in scope and propose solution for the project team to remediate the identified vulnerabilities in order to make the applications more secure.

The Security Assessment was performed by **Application Security Assessment Team, on 02nd March 2026.**

b. Objective

The objective of the tests performed was to:

- Identify the possible vulnerabilities and gaps
- Assess the gaps and vulnerabilities
- Suggest Recommendations to overcome existing vulnerabilities and gaps

This assessment report contains:

- Technical details of the vulnerabilities discovered with substantiation of the exploits.
- The risk mitigation recommendations that need to be implemented to ensure that the systems are secure from the risks arising due to the discovered vulnerabilities.

c. Scope

The scope for this Security assessment includes, but not limited to, the following tests:

- Information Gathering
- Configuration Management
- Business Logic
- Authentication
- Authorization
- Session Management
- Data Validation.

The following URL/IP Addresses were considered in scope for this assessment

URL
https://email.innovationsummit2026.accionlabs.com

d. Out of Scope

The following activities and applications were considered out of scope for this engagement:

- Social Engineering
- Denial of Service
- Buffer overflow

2. Summary of Findings

It was observed that the application is exposed to a total of **1** security vulnerabilities during the given assessment tenure with **1 - High**, **0 - Medium** and **0 - Low** severity vulnerabilities.

Sl. No	Vulnerability	Severity	Status
1	Subdomain Takeover via Dangling DNS	High	Open

3. Web Application Vulnerability Distribution by Severity

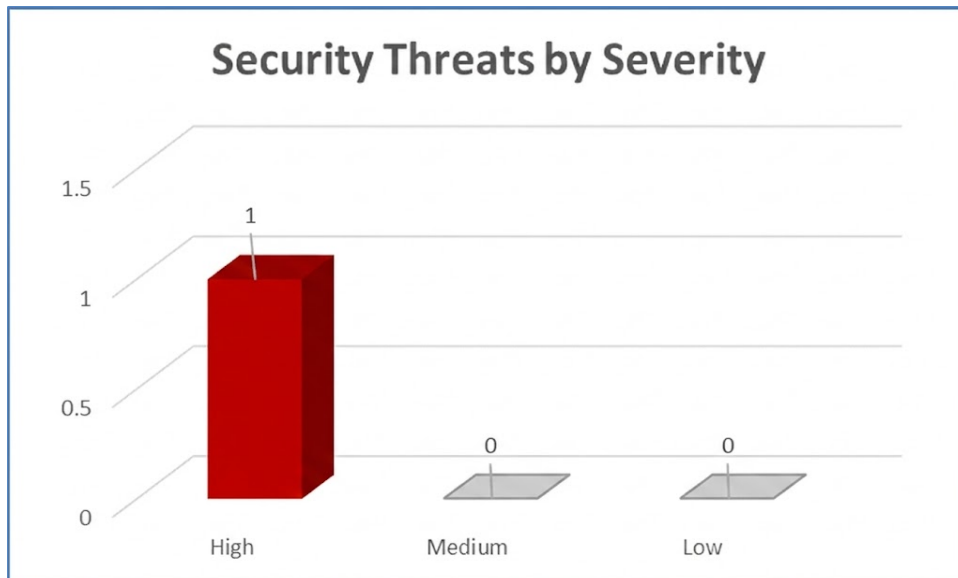


Figure1 – Vulnerability Distribution by Severity

4. Vulnerability Details

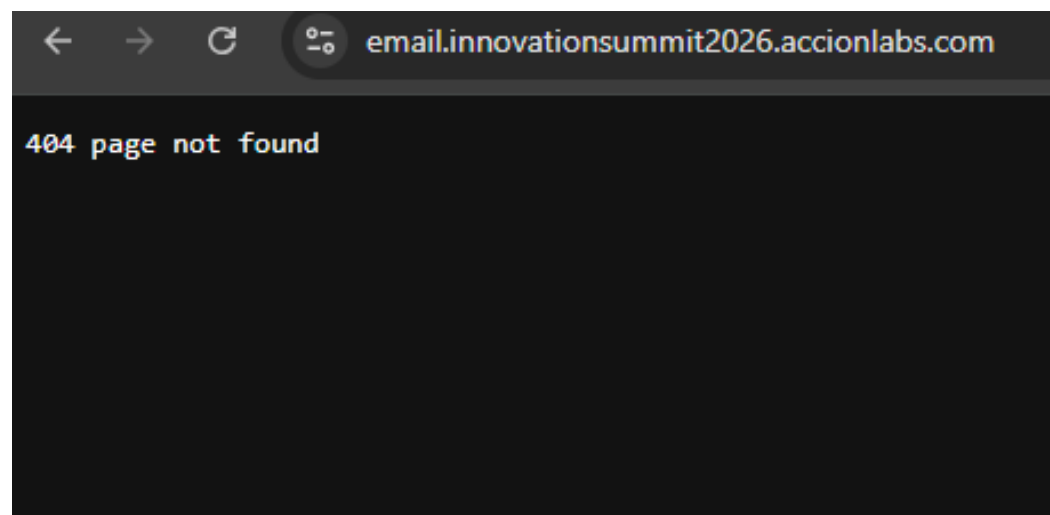
4.1 Subdomain Takeover via Dangling DNS		Severity: High	Status: Open
Observation	It is observed that "Dangling DNS" configuration was identified where a corporate subdomain points to a decommissioned third-party mail service (Mailgun). The external service provider still recognizes the DNS records, but the original account associated with them has been closed or abandoned.		
Affected URL's	https://email.innovationsummit2026.accionlabs.com		
Impact	Unauthorized control over the subdomain prevents the legitimate team from using their own infrastructure.		
CVSS Score	CVSS 3.1 score: 7.5 - 8.2		
Recommendation	• Remove the CNAME record for email.innovationsummit2026.accionlabs.com pointing to eu.mailgun.org. • Delete the MX records (mx.a.eu.mailgun.org and mx.b.eu.mailgun.org) to stop unauthorized email interception. • Purge the TXT/SPF records to prevent the delivery of "Authorized" spoofed emails that bypass spam filters.		
Reference	A05:2021 – Security Misconfiguration		
POC/ Steps to Reproduce			

1. Discovery & Reconnaissance:

- Initial reconnaissance using command-line interface (CLI) tools identified an active subdomain: email.innovationsummit2026.accionlabs.com.

```
[INF] Current httpx version v1.7.1 (outdated)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
https://email.innovationsummit2026.accionlabs.com
```

- External web requests to this address returned a standard **404 Not Found error**, indicating the underlying service was decommissioned but the **DNS** record remained **active**.



2. Affected DNS Analysis:

- Using the dig utility, the CNAME record was found to be pointing to Mailgun infrastructure (eu.mailgun.org).

```
Socroom# dig email.innovationsummit2026.accionlabs.com

; <<>> DiG 9.18.41-1~deb12u1-Debian <<>> email.innovationsummit2026.accionlabs.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 43250
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;email.innovationsummit2026.accionlabs.com. IN A

;; ANSWER SECTION:
email.innovationsummit2026.accionlabs.com. 3153 IN CNAME eu.mailgun.org.
eu.mailgun.org. 44 IN A 34.111.99.212
```

- This confirmed “**Dangling DNS**” vulnerability, as the external service provider was no longer associated with a valid Accion Labs account, leaving the subdomain available for unauthorized claims.

3. Exploitation & Hijacking:

- To demonstrate the exploit, a new Mailgun account was used to claim the "Unused" subdomain. By leveraging the existing DNS misconfiguration, I successfully verified:

Domains

Within the domains tab, you can seamlessly manage your email sending domains, ensuring optimal deliverability and security through customizable DNS settings.

Search all domains							
Name	Accepted (Mar)	Delivered (Mar)	Bounced (Mar)	Opened (Mar)	Clicked (Mar)	Complained (Mar)	
 email.innovationsummit2026.actionlabs.com	0	0%	0%	0%	0%	0%	

TXT (SPF) Records: Granting the ability to send authenticated emails as the subdomain.

Status	Type	Host (name)	Value (points to)
 Verified	TXT ⓘ	email.innovationsummit2026.actionlabs.com 	v=spf1 include:mailgun.org ~all  ...

MX Records: Redirecting all incoming mail flow to an attacker-controlled environment.

Receiving records

Install the provided MX records to route incoming mail through Mailgun, unless your domain already uses another provider (like Gmail) for receiving email. [Learn more about MX record setup.](#)

Status	Type	Host (name)	Value (points to)	Priority
 Verified	MX	email.innovationsummit2026.actionlabs.com 	mx.a.mailgun.org 	10 ...
 Verified	MX	email.innovationsummit2026.actionlabs.com 	mx.b.mailgun.org 	10 ...

4. Authentication & SMTP Proof of Concept (PoC):

- After generating API and SMTP credentials, a custom Python POC was executed to authenticate against the Mailgun server,

Mailgun API keys				
Status	Key ID ↕	Description ↕	Created date ↕	
✓	82cf32bf-565b01de	testing1	03/02/26	🗑️
✓	82cf32bf-931e4848	hijacked	03/02/26	🗑️

HTTP webhook signing key

*****5bfcb

This key is used to sign all HTTP payloads that we send to your webhook receivers. Check out the [documentation](#) for more information.

Settings DNS records SMTP credentials Sending keys Setup				
				Add new SMTP user
Login	Date created			
admin@email.innovationsummit2026.accionlabs.com	02/27/26 08:02 PM		Reset Password	Delete

- This confirmed that the account had full administrative authority over the corporate subdomain's mail identity.

```
Socroom# python3 mailgun3.py
Checking status for hijacked domain: email.innovationsummit2026.accionlabs.com
✅ SUCCESS: Total Administrative Control Proven.
Domain State: unverified
Created At: Fri, 27 Feb 2026 14:29:13 GMT
```

5. Evidence & Trace Logs:

The following logs demonstrate the successful interception and acceptance of mail traffic by the hijacked infrastructure:

Timestamp (US/Eastern) ⌵	Event ⌵	From ⌵	Recipient address
03/01/26 10:34:58 PM	☐ Rejected	☐ security@email.innovationsummit2026.accionlabs.com	

```
1 {
2   "@timestamp": "2026-03-02T03:34:58.007Z",
3   "account": {
4     "id": "69a18f72faa3b58c3bb6f51e"
5   },
6   "domain": {
7     "name": "email.innovationsummit2026.accionlabs.com"
8   },
9   "event": "rejected",
10  "flags": {
11    "is-authenticated": true,
12    "is-delayed-bounce": false,
13    "is-routed": false,
14    "is-system-test": false,
15    "is-test-mode": false
16  },
17  "id": "AdvvV8ayQmSy4UVURV4ZWA",
18  "message": {
19    "headers": {
20      "from": "security@email.innovationsummit2026.accionlabs.com",
21      "message-id": "20260302033458.e61a8806ed3afb4d@email.innovationsummit2026.accionlabs.com",
22      "subject": "EXPLOIT: Authorized Domain Impersonation",
23      "to": "RECIPIENT@example.com"
24    }
25  },
26  "originating-ip": "14.96.155.142",
```

Management Response	
Re-Test Result	

5.VAPT Methodology

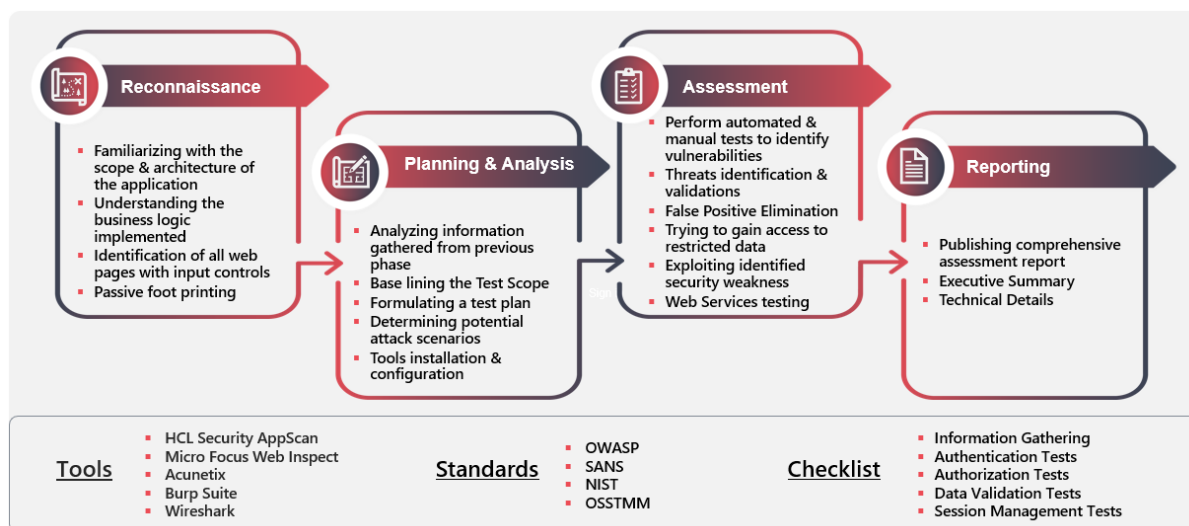


Figure2 – VAPT Methodology

Footprinting: Footprinting is the blueprinting of the security profile of an organization, undertaken in a methodological manner.

Expected outcomes: Live devices, DNS Information, etc.

Port Scanning: Port scanning is the invasive probing of system ports on the transport and network level. Included here is also the validation of system reception to tunneled, encapsulated, or routing protocols. This module is to enumerate live or accessible Internet services

Expected outcomes: Open port details

Enumeration: Service and operating system fingerprinting is the best way to define Enumeration. Service fingerprinting is used to discover the service version. OS fingerprinting is used to discover the operating system of the target IP. OS fingerprinting is the term used for the method that is used to determine the operating system that is

running on the target system. The two different types of fingerprinting are active fingerprinting and passive fingerprinting.

Expected outcomes: Operating system and its version, Services running, etc.

Vulnerability Discovery: Scanning for known vulnerabilities using vulnerabilities scanners.

Expected outcomes: Vulnerabilities present

Exploit research: Consultant test the exploit before using it in production at customer place to make sure impact of exploitation is not going to harm the business.

- Vulnerability found needs to be checked for exploitation.
- Modification of existing exploits according to the requirement.
- Developing new exploits if no suitable exploits available

Exploitation: After research and testing of the exploits, actual exploitation of the vulnerability on the target system

Privilege Escalation: Attempt to get Admin privileges

Reporting: Executive summary with Summary of findings and Recommendations Detailed Technical Findings such as Vulnerability details, Business Impact to the company, Recommendations and Proof of Concept for the exploits.

5.1 Vulnerability Risk Classification

Critical: These findings identify conditions that could cause extreme damage or directly result in the compromise or unauthorized access of a network, system, application or information. Critical risks must be fixed as soon as possible.

High: These findings identify conditions that could cause huge damage or directly result in the compromise or unauthorized access of a network, system, application, device or information. High risks are recommended to get fixed soon after Criticals.

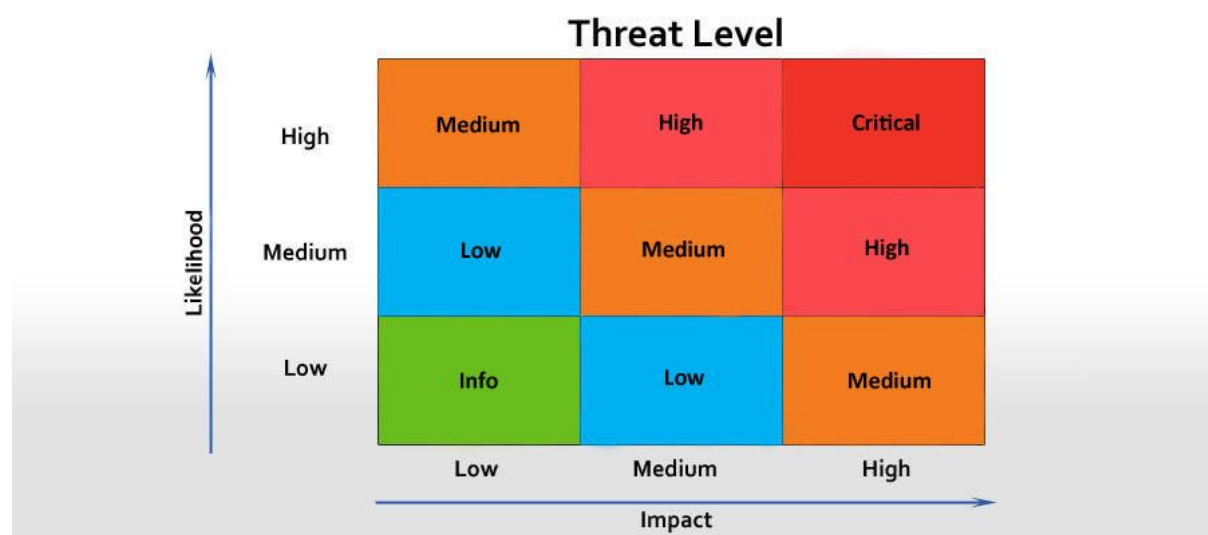
Medium: These findings identify conditions that could cause mediocre damage or that not directly or immediately compromise network, system, application, device or information. Medium risks are recommended to get fixed after High risks are addressed.

Low: These findings identify conditions that could cause minor damage or that not directly or immediately compromise or unauthorized access of a network, system, application, device or information. Low risks are recommended to get fixed after mediums.

Info: These are informational only. No direct threat to confidentiality, integrity or availability of the data, applications, systems or devices. The information can be used for awareness. It can also be used for hardening the security of the asset.

5.2 Threat Severity Risk Matrix

The severity of the risk using the matrix below. Each threat is measured using impact and likelihood. Combining both impact and likelihood gives the threat severity risk.



Procain Consulting & Services Pvt. Ltd

Protecting Confidentiality, Availability Integrity